Shreyas • S. Kanojia
44010426034

12/10/24

Case Study - 2

Securing the University Examination System

- A university uses an Operating System - based examination management system to store student records, examination marks, faculty details, and question papers. The System has three main user groups : Students, Faculty, and administrators. Students should be able to view only their own marks and download permitted learning materials. Faculty members need to view students records and enter or modify marks. Administrators manage user accounts, permissions, and system configuration.

- The university has assigned permissions through roles, but a audit review identifies the following events :

- At 10:00, the account Student07 has three failed login attempts.
- At 10:03, Student07 successfully logs in
- At 10:04, student 07 attempts to open ExamMarks.xlsx, which contains

Teacher's Signature:.....

marks for an entire class. an
- At 10:05, the system records
attempted modification of ExamMarks.
xlsx by Student07.
- At 10:15, Faculty02 modifies marks in
ExamMark.xlsx and saves the file
Successfully.
- At 10:20, an administrator discovers
that a former faculty member's
account is still active.
- The audit log is stored on the
same server, and users with broad
permissions may be able to modify
or delete it.

The university wants to protect confidentiality, integrity, and availability; prevent unauthorized access; maintain accountability and investigate suspicious activity. You are asked to recommend appropriate operating system access-control, security-administration, and auditing measures.

Teacher's Signature:.....

- Questions

q1) Identify the main security problems in the case study.

- List at least four risks or weaknesses indicated by the scenario.

q2) Explain the difference between authentication and authorization using Student07 as an example.

- Distinguish identity verification from permission checking.

q3) Recommend an access-control policy for Students, Faculty, and Administrators. Justify your choice.

- Consider how permissions should be assigned and managed

q4) Prepare a suitable Access Control List (ACL) for ExamMarks.xlsx.

- Specify appropriate Read, Write and Delete permissions for each user group.

Teacher's Signature:

g5) Explain how the Principle of least Privilege should be applied in this system.

- State what each group needs to do and which unnecessary permissions should be removed.

g6) Interpret the audit events from 10:00 to 10:05. What should the security team do next?

- Explain why the sequence is suspicious without assuming that it proves an attack.

g7) Identify at leeast five events that should be recorded in the audit logs.

- include login, file, account, permission and/or administrative events.

g8) Explain why the audit logs must be protected and recommend two ways to protect them.

- Consider unauthorized modification, deletion, and investigation.

Teacher's Signature:

Page No.:
Date :

Q9) What action should be taken regarding the former faculty member's active account? Explain.

- Relate your answer to account management and access removal.

Q10) Suggest a practical incident - response and corrective - action plan for the university.

- Include investigation, access review, policy changes, and follow - up monitoring

Page No.:
Date: / /

Ans1 -> Main security problems

- Weak login protection: Three failed logins were followed by a success, and nothing stopped it
- Excess permissions: Student07 could even attempt to open ExamMarks.xlsx.
- Unchecked mark changes: Faculty02 changed marks for a whole class with no approval or review.
- Stale account: A former faculty member's account is still active.
- Unprotected audit log: It sits on the same server, and broad-permission users can edit or delete it.

Ans2 ->

- Authentication checks who you are. Student07 proved their identity by logging in at 10:03 with the right password.
- Authorization checks what you're allowed to do. A student should only see their own marks, so opening ExamMarks.xlsx should be denied even though the login was valid.

Ans3 →

- Students: View their own marks and download permitted materials only. They get no write or delete rights.
- Faculty: View records and enter or edit marks only for their own courses. They cannot delete files or manage accounts.
- Administrators: Manage accounts, permissions and configuration. They should not edit marks routinely.

Permissions are given through roles, approved by a responsible authority, reviewed regularly, and removed when someone leaves or changes role. This keeps access matched to each person's job.

Ans4 →

User Group	Read	Write	Delete
• Students	No (own marks via portal only)	No	No
• Faculty	Yes (own courses)	Yes (own courses)	No
• Administrator	Yes	No (only with approval)	only with approval

Teacher's Signature.....

Ans 5 -> • Each group gets only what its work needs. Students need view-only access to their own data, so remove their access to other records and files.
• Faculty need marks entry for their own classes, so remove delete rights, admin rights and access to other departments.
• Admins need account and system management, so remove their ability to alter marks or audit logs.

Ans 6 -> • Three failed logins, then a successful login, then an attempt to open a restricted marks file, then an attempted modification. This is suspicious because it looks like password guessing followed by an attempt to reach data the student shouldn't touch. It doesn't prove an attack, though, as the student may simply have forgotten their password or been curious.

- The security team should:
1) Check whether the modification succeeded
2) Temporarily lock or monitor the account
3) Review the full logs and contact the student
4) Reset the password if needed.

Teacher's Signature:

Page No.
Date / /

Ans7→ Events that should be logged

1) Successful and failed logins
2) File access, modification and deletion
3) Account creation, disabling and deletion
4) Permission or role changes.
5) Administrative actions.

Ans8→

- Logs are the evidence for accountability and investigation. If someone can edit or delete them, they can hide their tracks, and the logs can't be trusted.

1) Store logs on a separate, central log server with write-only access.
2) Restrict log access to a few security staff, and use hashing or digital signatures plus backups to detect tampering.

Ans 9 →. Disable it immediately, then review what it did since the person left.

- Remove its permissions, reset credentials and delete it later according to retention policy.
- This is a failure of account management: when someone leaves, access removal must happen on their last day.
- An active old account is an easy way in for attackers, and it breaks accountability.

Ans 10 →

1) Investigation : Contain the issue, preserve the logs, and check Faculty02's 10:15 change and Student07's activity. Restore marks from backup if needed.

2) Access review : Audit all accounts and permissions, remove the former faculty account, and apply least privilege.

3) Policy Changes : Add account lockout and MFA, require approval for bulk mark changes, put logs on a protected server, and make account removal part of the exit process.

Teacher's Signature

4) Follow-up monitoring : Set alerts for failed logins and marks edits, do regular access reviews, and run staff awareness training